

Atividades práticas : Segurança e Auditoria em Sistemas de Informação e Gerência de Redes de Computadores

Auditoria de TI

Processo sistemático de coleta, organização, armazenamento e análises de evidências para determinar se um sistema de informação e os recursos relacionados protegem adequadamente os ativos, mantêm a integridade dos dados e atingem os objetivos da organização de forma eficaz e eficiente (QoS) Qualidade de Serviço.

Colunas da Segurança (CIA):

- **Confidencialidade:** A informação é acessível apenas por quem tem autorização?
- **Integridade:** A informação está correta, completa e é consistente em toda sua extensão (dimensão, caminho, fase) ?
- **Disponibilidade:** Os sistemas e dados estão acessíveis quando necessários?

Auditoria (objetivos):

- **Gestão de Riscos:** Identificar vulnerabilidades e ameaças.
- **Compliance (Conformidade):** Garantir o cumprimento de leis (ex: LGPD, GDPR), regulamentações (ex: SOX, BACEN) e padrões (ex: PCI-DSS).
- **Otimização de Recursos:** Verificar se os investimentos em TI estão sendo usados de forma eficiente.

Frameworks:

- **COBIT (Control Objectives for Information and Related Technologies):** Focado na governança e gerenciamento da TI, alinhando a TI aos negócios.
- **ISO 27001/27002:** Padrões focados na implementação e gestão de um Sistema de Gestão de Segurança da Informação (SGSI).
- **ITIL (Information Technology Infrastructure Library):** Foco na gestão de serviços de TI (este framework pode ser utilizado como método para auditoria, considerando como caminho a observação, validação e controle de seus processos).

Frameworks (complementos com padrões em ciência de dados e usando frameworks no padrão “**open standard**” (metodologias descritas como padrões abertos) apoiado por uma comunidade ampla, ativa, bem documentados com registros de atualizações e colaborações sempre bem referenciadas, atualizadas e com apoiadores do projeto.

Estrutura da abordagem: Governança, Auditoria e Gestão. Administração, gerenciamento e operação segura em redes de computadores. Segurança em sistemas de informação

(segurança de dados) e Ciência de Dados.

Referências de frameworks bases para **governança, auditoria e gestão, legalidades e conformidades**:

- NIST Cybersecurity Framework (NIST CSF)
- CIS Controls (Center for Internet Security)

Referências de frameworks para **SecDevOps**

- OWASP SAMM (Open Worldwide Application Security Project)

Referências de frameworks para **Threat Hunting** (caças e ameaças), **NIDS** (Network Intrusion Detection Systems) e operações (**ações pró-ativas**)

- MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge)

Convergência: Ciência de dados

Questões práticas :

1. Pesquisar, relacionar, descrever: (organizar informações, conceitos, fundamentos, características e aplicação) para :
 - 1.a. Pesquisar sobre o framework COBIT
 - 1.b. Pesquisar sobre o framework ITIL
 - 1.c. Pesquisar sobre ISO - Família 27.000 (relacionar as mais relevantes para este contexto) . Em detalhes: 27.001 e 27.002.

RESPOSTA:

O COBIT é um framework voltado para a governança e o gerenciamento da tecnologia, com o objetivo central de alinhar a TI aos negócios da organização. Já a ITIL (Information Technology Infrastructure Library) foca na gestão de serviços de TI e infraestrutura, podendo ser utilizada em auditorias para validar e controlar processos de serviço. Por fim, a família ISO 27000, com destaque para as normas 27001 e 27002, estabelece os padrões para a implementação e gestão de um Sistema de Gestão de Segurança da

Informação (SGSI), garantindo a proteção adequada dos ativos de dados.

2. Pesquisar , conceituar, descrever sobre: SecDevOp

Resposta:

SecDevOps (frequentemente tratado como sinônimo de DevSecOps) é uma filosofia e prática que incorpora a segurança da informação dentro da cultura e do fluxo de trabalho do DevOps (Desenvolvimento e Operações). O conceito central é a quebra dos "silos" entre as equipes: em vez de a segurança ser uma verificação final que atrasa o lançamento, ela se torna uma responsabilidade compartilhada durante todo o ciclo de vida do software.

A principal característica do SecDevOps é a mudança de paradigma conhecida como "Shift Left" (mover para a esquerda). Isso significa trazer as verificações de segurança para o início do processo de desenvolvimento (design e codificação), em vez de deixá-las para a direita (final/produção).

Automação de Segurança: Ferramentas de análise de código (SAST/DAST) rodam automaticamente a cada *commit* ou *build* no pipeline de CI/CD.

Segurança como Código (IaC): As configurações de infraestrutura e políticas de segurança são definidas via código, permitindo versionamento e auditoria.

Monitoramento Contínuo: O feedback sobre vulnerabilidades é imediato, permitindo que os desenvolvedores corrijam falhas enquanto o código ainda está "fresco" na mente, otimizando recursos e garantindo uma entrega ágil e segura.

3. Pesquisar, conceituar, descrever, apresentar características:

a. OWASP SAMM (Open Worldwide Application Security Project)

OWASP SAMM é um modelo aberto e flexível projetado para ajudar

organizações a formularem e implementarem uma estratégia de segurança de software (AppSec) que seja adaptável aos riscos específicos do negócio. Diferente de um checklist técnico, ele é um guia de maturidade para integrar segurança em todo o ciclo de vida do desenvolvimento (SDLC).

framework organiza a segurança em 5 Funções de Negócio, que se desdobram em 15 Práticas de Segurança. Cada prática pode ser avaliada em níveis de maturidade que vão do 0 (inexistente) ao 3 (otimizado/automatizado). Ele permite que a empresa avalie onde está ("Assessment") e defina um roteiro ("Roadmap") para onde quer chegar, sem exigir que todos atinjam o nível máximo em tudo imediatamente.

Algumas características são:

Agnóstico de Tecnologia: Funciona independentemente de a empresa usar Java, Python, Waterfall ou Agile/DevOps.

Estrutura de Maturidade (0-3): Permite evolução gradual.

- *Nível 1*: Ad-hoc/Simples (ex: fazemos teste de segurança quando dá).
- *Nível 2*: Estruturado/Padronizado (ex: teste de segurança é obrigatório em cada release).
- *Nível 3*: Otimizado/Automatizado (ex: testes rodam sozinhos no pipeline de CI/CD).

Foco em Processos: Cobre desde a Governança (Estratégia) até a Operação (Gestão de Incidentes), passando pelo Design (Modelagem de Ameaças) e Verificação (Testes).

b. MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge)

O MITRE ATT&CK é uma base de conhecimento global acessível que documenta o comportamento de cibercriminosos reais. Ele mapeia o *modus operandi* dos adversários (como eles invadem e se movem na rede), servindo como uma "tabela periódica" para descrever ações de ataque.

A estrutura é organizada em uma matriz de Táticas (o "quê" e o "porquê" - o objetivo do atacante, como "Acesso Inicial" ou "Exfiltração") e Técnicas (o "como" - o método específico, como "Phishing" ou "Injection"). Diferente de modelos que focam apenas em vulnerabilidades (como CVEs), o ATT&CK foca no TTP (Táticas, Técnicas e Procedimentos).

Visão do Atacante: Ajuda a defesa a pensar como o ataque.

Linguagem Comum: Padroniza a comunicação entre analistas. Em vez de dizer "tem um vírus", diz-se "identificamos a técnica T1059 (Command and Scripting Interpreter) da tática de Execução".

Aplicações Práticas:

- Threat Hunting: Caçar ameaças que escaparam das defesas tradicionais.
- Red Teaming: Simular adversários reais para testar a defesa.
- Gap Analysis: Verificar se suas ferramentas de segurança conseguem detectar as técnicas conhecidas.

4. Outros ... (?)

Se precisar complementar a lista "Outros", os mais indicados para este contexto são:

- NIST CSF (Cybersecurity Framework): Focado em gerenciar riscos cibernéticos com cinco funções pilares: Identificar, Proteger, Detectar, Responder e Recuperar. É excelente para falar com a diretoria (nível estratégico).
- CIS Controls (Center for Internet Security): Uma lista prescritiva de ações defensivas (ex: Inventário de Hardware, Inventário de Software). É o "feijão com arroz" técnico que deve ser feito antes de pensar em defesas complexas.

5. Frameworks para governança, auditoria e gestão:

a. NIST Cybersecurity Framework (NIST CSF)

O NIST CSF é um framework voluntário, desenvolvido pelo governo americano (National Institute of Standards and Technology), que fornece uma taxonomia comum e um mecanismo para organizações gerenciarem e reduzirem o risco de cibersegurança. O seu fundamento principal é facilitar a comunicação entre a equipe técnica e a alta gestão (executivos), traduzindo riscos técnicos em linguagem de negócios.

A estrutura é famosa por seu "Core" (Núcleo), organizado em funções que representam o ciclo de vida da gestão de incidentes. *(Nota: A versão 2.0 adicionou a função "Govern", mas a estrutura clássica ensinada baseia-se em 5 pilares):*

Identificar (Identify): Entender o ambiente, ativos e riscos (Ex: Inventário).

Proteger (Protect): Implementar controles preventivos para garantir a entrega de serviços (Ex: Controle de Acesso, Treinamento).

Detectar (Detect): Definir atividades para identificar ocorrências de eventos de

cibersegurança (Ex: Monitoramento contínuo).

Responder (Respond): Ações tomadas quando um incidente é detectado (Ex: Mitigação, Comunicação).

Recuperar (Recover): Planos para restaurar serviços afetados (Ex: Backups, Plano de Recuperação).

Na auditoria e governança, o NIST CSF é utilizado para criar um "Perfil Atual" (onde estamos) e um "Perfil Alvo" (onde queremos chegar), permitindo medir a maturidade da segurança e justificar orçamentos baseados em lacunas de risco.

b. CIS Controls (Center for Internet Security)

Os CIS Controls são um conjunto prescritivo e priorizado de melhores práticas (ações defensivas) para mitigar os ciberataques mais comuns. Enquanto o NIST diz "o que" fazer (gerenciar risco), o CIS diz "como" fazer tecnicamente (passo a passo). Seu conceito chave é a "Higiene Cibernética": focar no básico bem feito antes de tentar defesas complexas.

Os controles são organizados por prioridade e divididos em Grupos de Implementação (IGs) para ajudar empresas de diferentes tamanhos:

- IG1 (Higiene Básica): Controles essenciais que toda empresa *deve* ter (ex: Inventário de Hardware/Software, Gestão de Logs).
- IG2 e IG3: Controles para organizações com dados mais sensíveis ou maior risco. Na versão atual (v8), são 18 controles principais que cobrem desde a configuração segura de ativos até a proteção de dados e resposta a incidentes.

Para a gestão e auditoria técnica, o CIS Controls funciona como um checklist de verificação imediata. É excelente para definir métricas operacionais claras (ex: "temos 95% dos dispositivos inventariados") e reduzir a superfície de ataque de forma rápida e eficaz.

Questões práticas:

Convergência: Ciência de dados:

Referências : Linguagem python; DataSets; Análise Forense de Dados de Rede (registros de tráfego de redes)

1. Padrões de arquivos para os registros de dados (eventos, logs):
 - a. PCAP (binário / dados brutos)
 - b. JSON (semi-estruturado)
 - c. CSV (estruturado)
2. Repositórios públicos para Datasets: (recomendações: observem as informações, características, composições, metodologias utilizadas para compor o conjunto de

dados (tráfego de rede real, dataset sintético ou híbrido) ; Pesquise e visite os sites; Faça observações e selecione preferências de uso e interesses sobre os 3 padrões (.pcap ; .json; .csv)

- a. Wireshark Sample Captures
- b. Kaggle
- c. GitHub
- d. University New Brunswick, Canadá -
<https://www.unb.ca/cic/datasets/index.html>
- e. Cyber Range Lab of UNSW Canberra, Austrália -
<https://research.unsw.edu.au/projects/unsw-nb15-dataset>
- f. University of Queensland, Austrália (NetFlow Datasets) -
https://staff.itee.uq.edu.au/marius/NIDS_datasets/
- g. Stratosphere Lab -
<https://www.stratosphereips.org/datasets-overview>

3. Desenvolva códigos em python para utilizar esses arquivos

4. Apresenta ferramentas e recursos de bibliotecas python necessárias para realizar as análises exploratórias dos dados (EDA) e responder questões para reconhecimento dos dados, padrões de tráfego, de aplicação etc

5. Faça a integração de NIDS (Network Intrusion Detection Systems) com Machine Learning, descrevendo suas principais características, métodos e integrações com algoritmos aplicados.

Primeiramente, a base de dados escolhida foi uma do Kaggle, disponível no link:

<<https://www.kaggle.com/code/ricardotombesimacedo/an-lise-de-dados-par-a-seguran-a-de-redes>>

Essa base se chama Análise de Dados para Segurança de Redes.